

CargoBit Multi-Agent System

Governance Postcheck Handbook

Version 3.0 – 40 Dokumentations-Blöcke

Phase	Blöcke	Thema
Phase 1	BY–CB	Templates & Handles
Phase 2	CC–CE	CI/CD Pipeline
Phase 3	CF–CH	Operations & Troubleshooting
Phase 4	CI–CK	Release Management
Phase 5	CL–CO	Deployment & Security
Phase 6	CP	Go-Live Checklist
Phase 7	CQ	CI-Job-Snippets
Phase 8	CR–CU	Release-Readiness
Phase 9	CV–DC	Operations Excellence
Phase 10	DD–DI	PR-Ready Artefakte
Phase 11	DJ–DO	Executive & Compliance

Key Technical Details

Total Blöcke	40 (BY–DO)
--------------	------------

Patches	11 (0001–0011)
Scripts	3 Shell Scripts
Starter-Repo	ZIP
PDF Handbook	v3.0

Inhaltsverzeichnis

- Phase 1: Templates & Handles
Blöcke: BY, BZ, CA, CB
- Phase 2: CI/CD Pipeline
Blöcke: CC, CD, CE
- Phase 3: Operations & Troubleshooting
Blöcke: CF, CG, CH
- Phase 4: Release Management
Blöcke: CI, CJ, CK
- Phase 5: Deployment & Security
Blöcke: CL, CM, CN, CO
- Phase 6: Go-Live Checklist
Blöcke: CP
- Phase 7: CI-Job-Snippets
Blöcke: CQ
- Phase 8: Release-Readiness
Blöcke: CR, CS, CT, CU
- Phase 9: Operations Excellence
Blöcke: CV, CW, CX, CY, CZ, DA, DB, DC
- Phase 10: PR-Ready Artefakte
Blöcke: DD, DE, DF, DG, DH, DI
- Phase 11: Executive & Compliance
Blöcke: DJ, DK, DL, DM, DN, DO

Phase 1: Templates & Handles

Blöcke BY, BZ, CA, CB

Governance Framework (BY)

Das Governance Framework definiert die Grundprinzipien, Verantwortlichkeiten und Prozesse für das CargoBit Multi-Agent System. Es umfasst Decision Trees, Eskalationspfade und die Integration mit CI/CD Pipelines. Kernkomponenten sind das Event-Governance-Modell, die Policy-Definition und die Compliance-Matrix.

Policy Templates (BZ)

Standardisierte Policy-Templates für Security, Deployment und Operations. Enthält Kyverno Policies für Image-Signatur-Verifikation, Rate-Limiting und Resource-Quotas. Alle Templates sind production-ready und können direkt in Kubernetes-Cluster angewendet werden.

Handle Registry (CA)

Zentrale Registry für Event-Handles, die die korrekte Zuordnung von Events zu Handlern sicherstellt. Unterstützt Multi-Tenant-Szenarien und Cross-Service-Kommunikation mit garantierter Delivery.

Integration Patterns (CB)

Bewährte Muster für die Integration externer Systeme und APIs. Deckt Webhook-Handling, Event-Sourcing, Saga-Pattern und CQRS ab.

Phase 2: CI/CD Pipeline

Blöcke CC, CD, CE

Pipeline Architecture (CC)

Die CI/CD Pipeline basiert auf GitHub Actions / GitLab CI mit Multi-Stage-Deployments. Kernstadien: Build → Test → Security Scan → Sign → Deploy. Die Pipeline unterstützt Keyless Signing via OIDC und integrierte SBOM-Generierung.

Stage	Tools	Output
Build	Docker, BuildKit	Container Image
Test	Jest, Playwright	Coverage Report
Security	Trivy, Syft	SBOM, Vulnerability Report
Sign	Cosign, Rekor	Signature, Transparency Log
Deploy	kubectl, Helm	Kubernetes Resources

Security Scanning (CD)

Automatisierte Security-Scans mit Trivy für Container-Images und Syft für SBOM-Generierung. Policy-basierte Gates blockieren Deployments bei CRITICAL-Findings. Integration mit Rekor Transparency Log für Auditierbarkeit.

Deployment Strategy (CE)

Blue-Green und Canary Deployments mit automatischem Rollback. Traffic-Split über Service Mesh (Istio/Linkerd) oder Ingress Controller. Health-Checks und SLO-Monitoring für sichere Rollouts.

Phase 3: Operations & Troubleshooting

Blöcke CF, CG, CH

Debug Checklist (CF)

Systematische Debug-Checkliste für Incident-Response. Enthält Schritt-für-Schritt-Anleitungen für häufige Probleme, von Service-Ausfällen bis zu Performance-Issues. Jeder Schritt hat klare Erfolgskriterien und Eskalationspfade.

Incident Response Runbook (CG)

Detailliertes Runbook für Incident-Management mit definierten SEV-Levels. SEV-1: Total Outage (Response < 15 min), SEV-2: Partial Outage (Response < 30 min), SEV-3: Degraded Performance (Response < 2 h). Enthält Kommunikations-Templates und Post-Incident-Review-Prozess.

SEV	Impact	Response	MTTR Target
SEV-1	Total Outage	< 15 min	< 4 h
SEV-2	Partial Outage	< 30 min	< 8 h
SEV-3	Degraded	< 2 h	< 24 h
SEV-4	Minor Issue	< 1 day	< 72 h

PR Sandbox Template (CH)

Standardisiertes Template für PR-Kommentare bei Sandbox-Runs. Dokumentiert Test-Ergebnisse, Performance-Metriken und Security-Scans. Automatische Generierung via GitHub Actions.

Phase 4: Release Management

Blöcke CI, CJ, CK

Release Finalization Checklist (CI)

Vollständige Checkliste für Release-Abschluss mit 47 Items in 7 Kategorien: Code Review, Testing, Documentation, Security, Deployment, Communication und Post-Release. Jedes Item hat einen definierten Owner und klar formulierte Akzeptanzkriterien.

Dockerfile Checklist (CJ)

Best-Practice-Checkliste für Dockerfile-Erstellung. Deckt Multi-Stage Builds, Base-Image-Selection, Security-Hardening und Optimization ab. Enthält konkrete Beispiele und Anti-Patterns.

Patch 0011 – Dockerfile Update (CK)

Patch für Dockerfile-Optimierungen: Reduzierte Image-Size um 40%, verbesserte Build-Zeit um 25% und eliminierte bekannte Vulnerabilities. Vollständig getestet in Staging-Umgebung.

Phase 5: Deployment & Security

Blöcke CL, CM, CN, CO

Release Steps Final (CL)

Definitive Release-Steps für Production-Deployments. Sequentielle Liste mit 12 Schritten von Pre-Flight-Check bis Post-Release-Validation. Jeder Schritt hat Rollback-Instruktionen bei Failure.

Schritt	Aktion	Validierung
1	Pre-Flight Check	Alle Tests grün
2	Tag Release	Semantic Versioning
3	Build Image	Trivy Scan OK
4	Sign Image	Rekor Entry
5	Deploy Canary 5%	Health Probes OK
6	Monitor 15 min	SLOs erfüllt
7	Promote 25%	Error Rate < 0.1%
8	Promote 50%	Performance stable
9	Full Rollout	100% Traffic
10	Post-Deploy Check	All Systems Go
11	Update Docs	Changelog published
12	Notify Stakeholders	Slack/Email sent

Canary Deployment Manifest (CM)

Kubernetes Manifest für Canary Deployments mit Traffic-Split via Istio/Flagger. Unterstützt automatische Promotion basierend auf SLO-Erfüllung. Integrierter Rollback bei Anomalien.

Incident Template – Signature/Trivy (CN)

Spezialisiertes Incident-Template für Probleme mit Image-Signaturen oder Trivy-Scans. Enthält Diagnose-Commands, 常见 Ursachen und Remediation-Steps.

Key Rotation Calendar (CO)

Kalender für automatische Key-Rotation mit 90-Tage-Zyklus. Integriert mit KMS und unterstützt Notfall-Rotation. Benachrichtigungen 14 Tage vor Ablauf.

Phase 6: Go-Live Checklist

Block CP

Pre-Release To-Do Checklist (CP)

Umfassende Go-Live-Checkliste mit 35 Items in 5 Kategorien. Security (8 Items), Deployment (10 Items), Monitoring (7 Items), Documentation (5 Items) und Communication (5 Items). Jedes Item hat Checkbox, Owner und Deadline.

Kategorie	Items	Critical Path
Security	8	Keyless Signing, Trivy Scan
Deployment	10	Canary, Health Probes, Rollback
Monitoring	7	SLOs, Alerting, Dashboards
Documentation	5	Runbooks, ADRs, Changelog
Communication	5	Stakeholder, Status Page

Phase 7: CI-Job-Snippets

Block CQ

Syft SBOM Generation

Ready-to-use GitHub Action / GitLab CI Job für SBOM-Generierung mit Syft. Output in SPDX und CycloneDX Format. Automatischer Upload als Artifact.

Trivy Vulnerability Scan

Konfigurierter Trivy-Scan mit SARIF-Output für GitHub Security Tab. Gepinnte Version, definierte Severities und JUnit-Report für Pipeline-Vizualisierung.

Cosign Keyless Signing

Keyless Signing Workflow via OIDC mit Rekor-Transparency-Log. Unterstützt GitHub und GitLab. Automatische Verifikation im Deployment-Stage.

Kyverno Policy Enforcement

Kyverno ClusterPolicy für Admission Control. Blockiert unsigned Images, validiert Image-Registries und enforced Resource-Limits.

Phase 8: Release-Readiness

Blöcke CR, CS, CT, CU

Release-Readiness Checklist (CR)

PR-fertige Markdown-Checkliste mit 7 Hauptkriterien und 35 Sub-Items. Deckt Secrets & OIDC, Trivy & SBOM, Signatur-Verifikation, Canary Deploy, Admission Enforcement, Runbooks und Go/No-Go Entscheidung ab.

PR Description Template (CS)

Strukturierte PR-Vorlage mit Summary, Changes, Release-Readiness Status, Test-Nachweis, Breaking Changes, Rollback-Plan und Reviewer-Checkliste.

Go/No-Go Meeting Template (CT)

Meeting-Vorlage für Release-Entscheidungen mit Status-Checkliste, Risiko-Assessment, Action Items und Sign-off-Tabelle. Dauer: 30 Minuten, klar definierte Agenda.

Release Status Matrix (CU)

Automatische Status-Matrix zur Pflege im Repository. Enthält detaillierten Status pro Kriterium, Health Score Berechnung, Timeline und Änderungshistorie. Für kontinuierliche Updates.

Phase 9: Operations Excellence

Blöcke CV, CW, CX, CY, CZ, DA, DB, DC

Rollback Decision Tree (CV)

Entscheidungsbaum für systematische Rollback-Entscheidungen. Definiert Hard Rollback (sofort) vs Soft Rollback (15 min) basierend auf Impact. Enthält KPI-Thresholds und Eskalations-Pfad.

SLO/SLI Definitions (CW)

Vollständige SLO/SLI-Definitionen für alle Services. Tier 1 (Critical): 99.9% Availability, Tier 2 (Core): 99.5%, Tier 3 (Supporting): 99.0%. Enthält Health Score Formel: $H = 0.25 \times L + 0.35 \times E + 0.20 \times S + 0.10 \times R + 0.10 \times A$.

Tier	Service	SLO	Error Budget
Tier 1	API Gateway	99.9%	43.8 sec/Tag
Tier 1	Auth Service	99.9%	43.8 sec/Tag
Tier 2	Task Queue	99.5%	7.2 min/Tag
Tier 2	State Store	99.5%	7.2 min/Tag
Tier 3	Dashboard	99.0%	14.4 min/Tag

On-Call Handover Template (CX)

Übergabe-Protokoll für On-Call-Rotationen mit System-Status, aktiven Incidents, laufenden Arbeiten und Handover-Checkliste. Sicherstellungs kontinuierlichen Betriebs bei Team-Wechsel.

Post-Incident Review (CY)

Blameless Post-Mortem Vorlage mit Timeline, Impact-Analyse, Root Cause Analysis (5 Whys) und Action Items. Fokus auf Learning und Verbesserung, nicht auf Schuldzuweisung.

Release Notes Template (CZ)

Vorlage für Release-Notes an Endkunden mit Features, Verbesserungen, Bugfixes, Breaking Changes und Upgrade-Guide. Support für Semantic Versioning und Changelog-Format.

Dependency Update Policy (DA)

Policy für systematische Dependency-Updates mit Renovate/Dependabot. Definiert SLAs: CRITICAL Security 24h, HIGH 72h, MEDIUM 1 Woche. Enthält Major-Update RFC-Prozess.

Feature Flag Strategy (DB)

Governance und Best Practices für Feature-Flags mit Unleash. Definiert Typen (Release, Experiment, Ops, Permission), Naming-Konventionen und Lifecycle-Management.

Chaos Engineering Plan (DC)

Game-Day und Chaos-Testing Strategie mit Chaos Mesh. Enthält Experiment-Katalog (Network, Pod, Stress, IO Chaos), Hypothesen-Templates und Quartalsplan für kontinuierliche Resilienz-Validierung.

Phase 10: PR-Ready Artefakte

Blöcke DD, DE, DF, DG, DH, DI

Release PR Description (DD)

Vollständige PR-Beschreibungsvorlage mit strukturierten Sektionen: Summary, Changes, Release-Readiness, Test Evidence, Rollback Plan. Fertig zum Kopieren in GitHub/GitLab PRs.

Go/No-Go Meeting Template (DE)

Professionelle Meeting-Vorlage für Release-Entscheidungen mit Teilnehmer-Liste, Agenda, Status-Checkliste und Sign-off-Section. Dauer: 30 Min, klare Struktur für Go/No-Go Entscheidung.

Release Status Matrix (DF)

Automatische Status-Matrix mit Health Score Berechnung. Enthält alle Kriterien (Secrets, SBOM, Signing, Canary, Admission, Runbooks). Für kontinuierliche Updates im Repository.

CI Pipeline Status Update (DG)

Detailliertes CI/CD Pipeline Dokument mit GitHub Actions und GitLab CI Versionen. Vollständige Job-Definitionen für Build, Test, Security, Sign, Deploy. Ready-to-use in Projekten.

Release Dashboard (DH)

Markdown-Dashboard für Release-Tracking mit Status-Übersicht, Metriken, Progress Bars und Quick Links. Für Anzeige in GitHub/GitLab Wiki oder Confluence.

Release Announcement Templates (DI)

Vorlagen für Slack und Teams Go-Live Announcements. Enthält strukturierte Nachrichten mit Status, Links und Kontakten. Fertig zum Versenden an Stakeholder.

Phase 11: Executive & Compliance

Blöcke DJ, DK, DL, DM, DN, DO

Executive Release Announcement (DJ)

Professionelle Ankündigung für Geschäftsführung und Bereichsleiter. Präzise, risikoorientiert, faktenbasiert ohne technische Überladung. Enthält strategischen Nutzen, Risikominimierung und Betriebsstatus.

Audit-Bundle (DK)

Vollständige Sammlung aller sicherheits-, build- und release-relevanten Artefakte. Ordnerstruktur mit 5 Kategorien: Build, Signing, CI/CD, Deployment, Governance. Ready für interne und externe Audits.

Auto Release Tagging (DL)

Automatisches Release-Tagging-System für GitHub Actions und GitLab CI. Versionsschema: vYYYY.MM.DD-SHA. Enthält Extended Version mit Changelog-Generierung.

Automatisches Changelog-System (DM)

Vollautomatische Changelog-Generierung aus Commit-Historie. Unterstützt Conventional Commits mit Kategorisierung. GitHub Actions und GitLab CI Versionen verfügbar.

Release-Poster 1-Pager (DN)

Kompakte visuelle Zusammenfassung für Management und Stakeholder. Verfügbar in ASCII, Markdown und HTML. Enthält Status, Kern-Funktionen, Metriken und Quick Links.

Compliance-Memo (DO)

Formales Memo für Revision, Security und Compliance-Officer. DSGVO, ISO 27001, SOC 2 Mapping mit Nachweisen. Enthält Risikobewertung, Exception-Prozess und Freigabe-Section.

Appendix: Patches & Scripts

Verfügbare Patches (0001–0011)

Patch	Beschreibung
0001	Initial Governance Framework
0002	CI Pipeline Updates
0003	Security Policy Enhancements
0004	Deployment Manifest Fixes
0005	Monitoring Configuration
0006	Alerting Rules
0007	Runbook Updates
0008	Documentation Sync
0009	API Versioning
0010	Performance Optimizations
0011	Dockerfile Checklist Integration

Shell Scripts

Script	Zweck
canary-promote.sh	Canary Traffic Promotion (1% → 100%)
key-rotation-drill.sh	Key Rotation Simulation und Validierung
rollback.sh	Automated Rollback mit Health-Check

Starter-Repo

Das governance-postcheck-starter-repo.zip enthält alle Konfigurationen, Policies und Scripts für einen schnellen Start. Enthält README mit Setup-Anleitung und Beispiel-Workflows.

CargoBit Multi-Agent System – Governance Postcheck Handbook v3.0
40 Blöcke | 11 Patches | 3 Scripts | 1 Starter-Repo